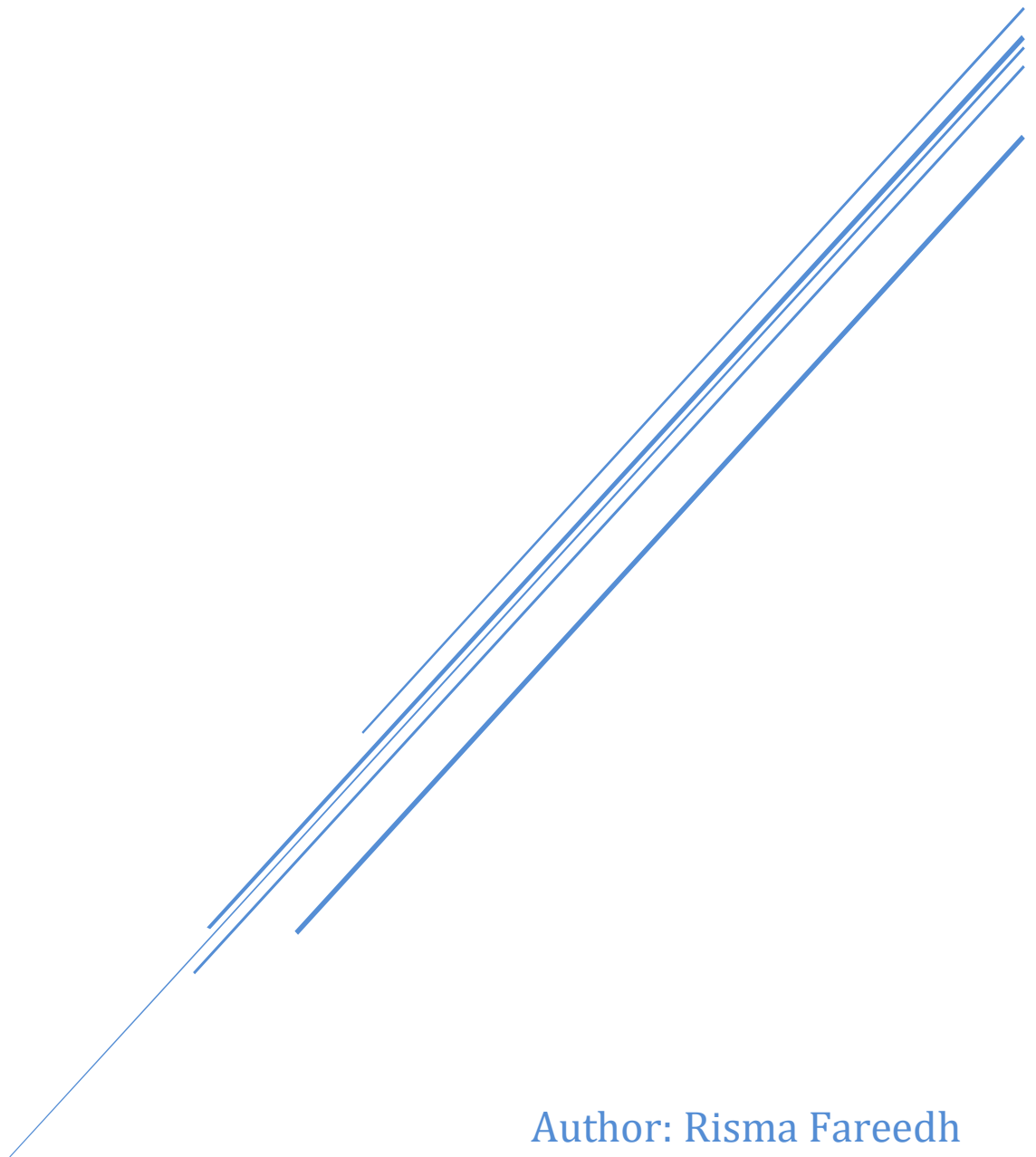


ISO 27001 GAP ASSESSMENT REPORT

For Banking Industry



Author: Risma Fareedh
AION Campus
Governance, Risk, Compliance (GRC)

Overview

Here provides an overview of the current ISO/IEC 27001:2022 gap assessment results for Q Bank (fictional Bank).

Out of 26 key requirements assessed:

- 6 requirements (23.1%) are fully implemented.
- 11 requirements (42.3%) are partially implemented.
- 9 requirements (34.6%) are currently missing.

The results indicate that while Q Bank has a foundational security posture in place, several critical areas such as risk assessment methodology, Statement of Applicability, internal audits, and corrective action processes require urgent attention. Management commitment and resources will be essential to close these gaps and achieve ISO 27001 certification.

4. Context of the Organization

Sub-Section	Requirement	ISO/IEC 27001 Requirement	Reqs Met?	Comments	Action Needed	Action Owner
4.1	Understanding the organization and its context	Bank must identify internal/external issues affecting ISMS.	Partial	SWOT analysis done but not formally documented.	Develop a formal context analysis document.	Risk & Compliance Dept.
4.2	Understanding the needs and expectations of interested parties	Identify customers, regulators, shareholders, vendors and their requirements.	Partial	Regulatory requirements identified, vendor requirements missing.	Maintain Interested Parties Register.	Compliance Dept.
4.3	Determining the scope of the ISMS	Define boundaries of ISMS covering critical services, systems, and sites.	Yes	Scope drafted for Core Banking, ATMs, Internet/Mobile Banking.	Annual review required.	CISO
4.4	Information security management system	Establish, implement, maintain, and continually improve ISMS.	Partial	ISMS manual exists but not aligned to 2022 update.	Update ISMS manual to 2022 version.	ISMS Manager

5. Leadership

Sub-Section	Requirement	ISO/IEC 27001 Requirement	Reqs Met?	Comments	Action Needed	Action Owner
5.1	Leadership and commitment	Top management must show active involvement.	Yes	Board approved ISMS project, quarterly reviews planned.	Ensure minutes are documented.	CISO / Board
5.2	Policy	Information Security Policy aligned with bank objectives.	Partial	Draft exists but not signed by top management.	Finalize and publish policy.	CISO
5.3	Organizational roles, responsibilities and authorities	Roles must be clearly defined.	Yes	RACI matrix created for IT and business units.	Ongoing updates.	HR + CISO

6. Planning

Sub-Section	Requirement	ISO/IEC 27001 Requirement	Reqs Met?	Comments	Action Needed	Action Owner
6.1.1	Actions to address risks and opportunities	Plan actions to address risks and opportunities.	Partial	Initial risk register created.	Formalize risk treatment plans with owners.	Risk Mgmt Team
6.1.2	Information security risk assessment	Establish methodology and perform regular risk assessments.	No	Only ad-hoc risk reviews conducted.	Develop formal risk methodology (impact/likelihood).	Risk Mgmt Team
6.1.3	Information security risk treatment	Establish SoA and treatment plan.	No	No Statement of Applicability yet.	Prepare SoA referencing Annex A controls.	ISMS Manager
6.2	Information security objectives and planning	Set measurable objectives aligned with ISMS.	Partial	Target exists (reduce phishing), but not across all units.	Expand SMART objectives bank-wide.	CISO / Unit Heads

7. Support

Sub-Section	Requirement	ISO/IEC 27001 Requirement	Reqs Met?	Comments	Action Needed	Action Owner
7.1	Resources	Adequate resources must be provided.	Yes	Budget allocated for SIEM, DLP.	Monitor resource adequacy annually.	IT & Finance
7.2	Competence	Staff must have appropriate competence.	Partial	Some staff trained, others not.	Conduct mandatory ISO 27001 awareness training.	HR & CISO
7.3	Awareness	Awareness across all employees.	No	No structured awareness program.	Develop quarterly awareness campaign.	HR / IT Security
7.4	Communication	Internal/external ISMS communication plan.	Partial	Incident communication not formalized.	Create ISMS communication policy.	CISO
7.5.1	Documented information – General	Proper documentation system.	Partial	Some documents not version controlled.	Implement document management system.	Compliance
7.5.2	Creating and updating	Control for document creation and updates.	Partial	Document templates exist, but review cycle weak.	Formalize review/approval process.	Compliance
7.5.3	Control of documented information	Ensure documents are available and protected.	Partial	Distribution and retention policy unclear.	Establish lifecycle document management.	Compliance

8. Operation

Sub-Section	Requirement	ISO/IEC 27001 Requirement	Reqs Met?	Comments	Action Needed	Action Owner
8.1	Operational planning and control	Implement planned processes.	Partial	Processes exist but lack monitoring.	Document operational procedures.	IT & Ops
8.2	Information security risk assessment	Conduct risk assessments regularly.	No	Not institutionalized.	Schedule periodic risk assessments.	Risk Mgmt Team
8.3	Information security risk treatment	Implement chosen risk treatments.	Partial	Patch mgmt and encryption ongoing.	Document evidence for all treatments.	IT Security

9. Performance Evaluation

Sub-Section	Requirement	ISO/IEC 27001 Requirement	Reqs Met?	Comments	Action Needed	Action Owner
9.1	Monitoring, measurement, analysis and evaluation	Monitoring and measurement required.	Partial	SIEM in place but limited KPIs.	Define ISMS KPIs and dashboards.	CISO
9.2.1	Internal audit – General	Internal audits required.	No	None conducted yet.	Plan and execute internal audit cycle.	Internal Audit
9.2.2	Internal audit programme	Maintain audit program.	No	No annual audit program yet.	Draft internal audit programme.	Internal Audit
9.3.1	Management review – General	Top mgmt reviews ISMS.	Partial	Review planned but not held.	Conduct quarterly reviews.	CISO / Board
9.3.2	Management review inputs	Review inputs must include risks, audit results.	No	Not yet structured.	Define mgmt review agenda & inputs.	CISO
9.3.3	Management review results	Document review outputs.	No	Not applicable yet.	Record and track action items.	Compliance

10. Improvement

Sub-Section	Requirement	ISO/IEC 27001 Requirement	Reqs Met?	Comments	Action Needed	Action Owner
10.1	Continual improvement	ISMS must continually improve.	Partial	Some improvements tracked.	Define continual improvement log.	CISO
10.2	Nonconformity and corrective action	Nonconformities tracked and corrected.	No	No corrective action process yet.	Develop CAPA process.	Risk & Compliance